

CO1 AT3

Name : K. Sujith Sai Vignesh

Reg No : 192311199

Course Code : ITA1408

Course Name : Ethical Hacking.

Exploiting SQL Injection Vulnerability

Goal of Penetration is to demonstrate the vulnerability without compromising the clients real data.

A professional Penetration tester follows ethical guidelines and minimizes the risk.

How to Proceed without causing harm

1) Stop before exploiting causing harm vulnerability fully

- Confirm that the SQL Injection exists using safe, non-destructive Payloads
- Avoid queries that modify delete or dump large amounts of customer data.

2) Use minimal - impact testing

- Retrieve only the minimum amount of information required to prove the vulnerability [Eg: Database Version or current database name].

- Do not access or expose sensitive financial records unless explicitly authorized.

3) Notify the client immediately

- Inform the Project manager or the client's Point of contact that the vulnerability affects production data.
- Request approval before performing any further exploitation.

4) Follow the agreed Rules of Engagement (RoE)

- Only perform actions that are explicitly permitted in the signed scope.
- If full exploitation is outside the agreed scope, do not proceed.

5) Document your findings

- Record how the vulnerability was identified
- Explain the potential impact [Eg - Unauthorized access to financial data.]
- Provide remediation recommendations without exposing sensitive customer information in the given report.

Precautions that should have been taken before the Engagement

Before the Penetration test began, the following should have been established:

* Clear Rules of Engagement (RoE)

- Define whether Production Systems can be exploited.
- Specify which tests are allowed & prohibited.

* Written authorization

- Obtain formal Permission for testing Production environments.

* Use of a Staging / Test environment

- Whenever possible, Perform exploit testing against a non Production environments. containing Sanitized or dummy data.

* Data Protection Measures

- Mask or anonymize Sensitive customer information.
- Ensure compliance with Privacy regulations (such as GDPR or similar to the applicable laws for the data protection).

* Backup and Recovery Plan

- Verify that recent backups exist in case any unexpected issue occurs.

* Communication Plan

- Identify client contacts & define an escalation process if a critical vulnerability is discovered.

* Emergency Stop Procedure.

- Establish criteria for immediately halting testing if there is a risk of disrupting business operations or exposing the customer data.

* Obtain written authorization from the client to perform the assessment to process

* Whenever possible, conduct testing in a staging or test environment instead of production environment

* Establish communication and escalation plan for reporting of the critical vulnerabilities immediately to the authorities.

* Avoid Disrupting Business Operations

- Production databases are actively used by customers and employees.
 - Running heavy SQL queries
 - Performing Denial of Service Attacks
 - Locking Database tables
 - Consuming excessive CPU or memory
 - Causing application downtime.
- Testing should always be conducted in a way that does not affect the normal business operations.

* Protect Customer Privacy.

Financial Information is highly sensitive

Testers must never

- copy customer records unnecessarily
- store sensitive information on personal devices
- share screenshots containing customer information
- include confidential records in final report.

Example:

Instead of

Credit Card: 4532 - 1234 - 5678 - 1921

Use

Credit Card: XXXX - XXXX - XXXX - 1921

This protects customer privacy while still demonstrating the issue.

Conclusion:

A Professional Ethical hacker should prove the existence of the SQL (Structured Query Language) Injection while minimizing impact, avoid unnecessary access to customer financial data, obtain client approval before any deeper exploitation, & strictly follow the agreed Rules of Engagement. Proper planning - including authentication, a well-defined scope, use of test environments, data protection measures - should be completed before the engagement of the testing begins.